

Circular sobre protección de datos de pacientes — versión 1

Dña. Marta Solís Echevarría

Circular interna — Protección de datos personales de pacientes

Fecha: 15 de marzo de 2024. Dirigida a: todo el personal de Clínica Delos.

1. Objeto

La presente circular tiene por objeto recordar y actualizar las obligaciones de todo el personal de Clínica Delos en materia de protección de datos personales de los pacientes, conforme al Reglamento General de Protección de Datos (UE) 2016/679 (RGPD) y la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (LOPDGDD).

El tratamiento de datos de salud se considera un tratamiento de categorías especiales de datos (artículo 9 del RGPD), lo que exige un nivel de protección reforzado y medidas técnicas y organizativas adecuadas.

2. Responsable del tratamiento

Clínica Delos S.L. es responsable del tratamiento de los datos personales de sus pacientes. El Delegado de Protección de Datos (DPD) es D. Fernando Arrieta Godoy, contactable en dpd@clinicadelos.es.

3. Bases jurídicas del tratamiento

Los datos de los pacientes se tratan al amparo de las siguientes bases jurídicas:

- **Prestación asistencial:** artículo 9.2.h) del RGPD (fines de medicina preventiva, diagnóstico médico, prestación de asistencia sanitaria).
- **Obligación legal:** conservación de historias clínicas conforme a la Ley 41/2002, de 14 de noviembre, básica reguladora de la autonomía del paciente.
- **Interés vital del interesado:** en situaciones de urgencia en las que el paciente no pueda prestar consentimiento.

4. Categorías de datos tratados

- Datos identificativos: nombre, apellidos, DNI/NIE, fecha de nacimiento, domicilio, teléfono, correo electrónico.
- Datos de salud: historia clínica, informes diagnósticos, resultados de pruebas, prescripciones farmacológicas, datos genéticos cuando proceda.
- Datos administrativos: datos de aseguradora, número de póliza, datos de facturación.

5. Periodo de conservación

Los datos contenidos en la historia clínica se conservarán durante un periodo mínimo de **5 años** desde la fecha del último episodio asistencial, conforme a la Ley 41/2002 y la normativa autonómica de aplicación.

Transcurrido este periodo, los datos podrán ser anonimizados para fines estadísticos o de investigación, o destruidos de forma segura mediante los procedimientos aprobados por el DPD.

Los datos administrativos y de facturación se conservarán durante los plazos de prescripción fiscal y mercantil aplicables (generalmente 4 a 6 años).

6. Medidas de seguridad

Todo el personal debe observar las siguientes medidas:

Acceso a la información

- Acceder únicamente a los datos de los pacientes que sean estrictamente necesarios para el desempeño de sus funciones.
- No compartir credenciales de acceso al sistema de historia clínica electrónica (HCE).
- Bloquear la sesión del ordenador al ausentarse del puesto de trabajo, incluso por periodos breves.

Comunicación de datos

- No facilitar datos de pacientes por teléfono sin verificar previamente la identidad del interlocutor.
- Las comunicaciones por correo electrónico que contengan datos de salud deben enviarse cifradas o a través del sistema seguro de mensajería interna.
- Prohibida la transmisión de datos de pacientes por aplicaciones de mensajería instantánea (WhatsApp, Telegram, etc.).

Documentación en papel

- Las historias clínicas en papel se custodian en el archivo centralizado con control de acceso.
- Los documentos con datos de pacientes que ya no sean necesarios deben destruirse mediante las destructoras de documentos habilitadas en cada planta.
- Prohibido dejar documentos con datos de pacientes en lugares accesibles a personas no autorizadas.

7. Derechos de los pacientes

Los pacientes pueden ejercer sus derechos de acceso, rectificación, supresión, limitación del tratamiento, portabilidad y oposición mediante solicitud escrita dirigida al DPD. El plazo de respuesta es de un mes desde la recepción de la solicitud, prorrogable por dos meses en casos de especial complejidad.

8. Notificación de brechas de seguridad

Cualquier empleado que detecte o sospeche una brecha de seguridad que afecte a datos de pacientes debe comunicarlo de inmediato al DPD a través del canal de incidencias habilitado en la intranet. El DPD valorará la necesidad de notificar a la AEPD en el plazo de 72 horas establecido por el RGPD.

Se considera brecha de seguridad, entre otros: el acceso no autorizado a historias clínicas, la pérdida o robo de dispositivos que contengan datos de pacientes, el envío de información a destinatarios erróneos o la destrucción no planificada de datos.

9. Régimen sancionador

El incumplimiento de las obligaciones en materia de protección de datos puede dar lugar a:

- **Sanciones disciplinarias internas:** conforme al régimen disciplinario del convenio colectivo.
- **Responsabilidad administrativa:** multas de la AEPD que pueden alcanzar los 20 millones de euros o el 4 % de la facturación anual.

- **Responsabilidad civil y penal:** en los casos más graves de revelación de secretos profesionales.

10. Formación

Todo el personal recibirá formación obligatoria en protección de datos al inicio de su relación laboral y una sesión de actualización anual. La asistencia se registra y forma parte de la evaluación del desempeño.

Firmado: Dña. Marta Solís Echevarría · Directora de asesoría jurídica · Clínica Delos · 15 de marzo de 2024.